

CYROPAY LTD

Privacy and Personal Data Protection Policy

Document Information

Document ID	POL-009
Document Classification	Internal
Version	1.0
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Effective Date	May 2026
Review Date	May 2027
Status	Approved

1. Purpose

This Privacy and Personal Data Protection Policy establishes CyroPay Ltd's commitment to protecting the personal data of customers, employees, and other individuals in accordance with the UK General Data Protection Regulation (UK GDPR), the Data Protection Act 2018, and applicable FCA requirements. As an FCA-authorised payment institution, CyroPay processes significant volumes of personal and financial data and must demonstrate accountability for its protection.

The policy addresses gaps identified in CyroPay's ISO 27001:2022 gap assessment including inconsistent application of privacy by design principles and the need to strengthen the DPIA process.

2. Scope

This policy applies to all personal data processed by CyroPay in any format including digital records, databases, emails, physical documents, and verbal communications. It applies to all employees, contractors, and third parties who process personal data on CyroPay's behalf. It covers personal data relating to customers, merchants, employees, and any other identified or identifiable individuals.

3. Definitions

Term	Definition
Personal Data	Any information relating to an identified or identifiable living individual
Processing	Any operation performed on personal data including collection, storage, use, disclosure, and deletion
Data Subject	The individual whose personal data is being processed
Data Controller	CyroPay Ltd — the entity that determines the purposes and means of processing personal data
Data Processor	A third party that processes personal data on CyroPay's behalf
DPIA	Data Protection Impact Assessment — a process to identify and mitigate privacy risks before processing begins
Lawful Basis	The legal justification for processing personal data under UK GDPR Article 6

DPO	Data Protection Officer — the individual responsible for overseeing data protection compliance
ICO	Information Commissioner's Office — the UK data protection supervisory authority
Special Category Data	Sensitive personal data requiring enhanced protection under UK GDPR Article 9

4. Roles and Responsibilities

4.1 Data Protection Officer (DPO)

- Monitor compliance with UK GDPR and this policy
- Advise on DPIAs and high-risk processing activities
- Act as the primary point of contact with the ICO
- Manage data subject rights requests

4.2 CISO

- Ensure technical and organisational security measures protect personal data
- Oversee the information security aspects of data protection compliance
- Manage personal data breach response in coordination with the DPO

4.3 All Employees

- Process personal data only for legitimate business purposes and in accordance with this policy
- Report actual or suspected personal data breaches to the DPO immediately
- Complete mandatory data protection training annually

4.4 Head of Development

- Ensure privacy by design is embedded in all development activities
- Ensure DPIAs are completed for all high-risk processing activities before development begins

5. Policy Requirements

5.1 UK GDPR Principles

CyroPay must comply with all six UK GDPR data protection principles for all personal data processing:

- Lawfulness, fairness, and transparency — process data lawfully with a documented legal basis and provide clear privacy notices
- Purpose limitation — collect data only for specified, explicit, and legitimate purposes and do not process further in incompatible ways
- Data minimisation — collect only the minimum personal data necessary for the stated purpose
- Accuracy — keep personal data accurate and up to date. Implement processes to correct inaccurate data promptly
- Storage limitation — retain personal data only for as long as necessary. Maintain and enforce a data retention schedule
- Integrity and confidentiality — protect personal data against unauthorised access, loss, and destruction using appropriate technical and organisational measures

5.2 Lawful Basis for Processing

- A documented lawful basis under UK GDPR Article 6 must be identified for every category of personal data processing before processing begins
- For special category data, an additional condition under Article 9 must be identified and documented
- The Records of Processing Activities (ROPA) must be maintained and kept up to date by the DPO

5.3 Privacy by Design

- Privacy by design principles must be embedded in all new systems, applications, and processes from the outset
- The Head of Development must ensure a DPIA is completed for any new or significantly changed processing that is likely to result in high risk to individuals
- DPIAs must be completed before processing begins, not after
- Privacy notices must be reviewed and updated whenever the processing of personal data changes

5.4 Data Subject Rights

CyroPay must respond to data subject rights requests within the statutory timeframes:

- Right of access (Subject Access Request) — respond within one calendar month
- Right to erasure — assess and respond within one calendar month
- Right to rectification — correct inaccurate data without undue delay
- Right to restrict processing — implement restriction within one calendar month
- Right to data portability — provide data in a structured, machine-readable format
- All data subject rights requests must be logged and tracked by the DPO

5.5 Personal Data Breach Management

- Any actual or suspected personal data breach must be reported to the DPO immediately upon discovery
- The DPO must assess whether the breach is notifiable to the ICO within 72 hours of becoming aware under UK GDPR Article 33
- Where a breach is likely to result in high risk to individuals, affected data subjects must be notified without undue delay
- All breaches must be recorded in the breach register regardless of whether ICO notification is required

5.6 Third-Party Data Processing

- All third parties processing personal data on CyroPay's behalf must be subject to a Data Processing Agreement (DPA) prior to processing
- DPAs must include all mandatory UK GDPR Article 28 clauses
- Third-party processors must be assessed for data protection compliance as part of the supplier onboarding process

5.7 International Data Transfers

- Personal data must not be transferred outside the UK without an appropriate transfer mechanism in place
- Approved transfer mechanisms include UK adequacy decisions and Standard Contractual Clauses (SCCs)
- All international transfers must be documented in the ROPA

5.8 Data Retention and Deletion

- Personal data must be retained only for the periods defined in the CyroPay Data Retention Schedule
- Personal data must be securely deleted or anonymised at the end of its retention period
- Payment data retention periods must comply with PCI DSS requirements

6. Compliance and Monitoring

Compliance with this policy shall be monitored through:

- Internal audits and policy reviews
- Risk assessments and vulnerability assessments
- Security monitoring activities

- Management review meetings

Violations of this policy may result in disciplinary action, termination of access privileges, or legal escalation where appropriate.

7. Exceptions

Any exception to this policy must:

- Be formally documented with a business justification
- Be risk assessed and approved by the CISO
- Include compensating controls where necessary
- Be reviewed periodically and include an expiration date if temporary

8. Related Documents

- POL-001 Information Security Policy
- POL-005 Incident Response Policy
- POL-006 Data Classification and Handling Policy
- POL-008 Secure Development Policy

9. ISO 27001 Annex A Mapping

Annex A Control	Description
A.5.31	Legal, statutory, regulatory and contractual requirements
A.5.33	Protection of records
A.5.34	Privacy and protection of personally identifiable information
A.8.10	Information deletion
A.8.11	Data masking

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version